

PAPER: Governance-Native Communication with Causal Provenance for Human–AI Software Engineering Systems

Patrick Rho
Patty Research

August 2026

Abstract

AI coding systems increasingly act as long-running software-engineering agents: they select repository context, invoke models, call tools, edit files, and affect source-control history. Conventional model APIs authenticate and transport requests efficiently, but organizations commonly reconstruct authorization, enforcement, and provenance after the fact from gateways and logs. This separation makes it difficult to establish which enrolled client and user were authorized to cause an action, which immutable policy governed it, which model artifact served it, what enforcement occurred before execution, and how the output later affected source code.

We present PAPER (Patty AI Provenance & Enforcement Relay), a stateful application protocol whose principal unit is a *Governed Exchange*. A protected exchange binds authenticated peer and user identities to a short-lived Capability Lease, immutable Policy Epoch, inline Relay Verdicts, server-authoritative model identity, and a content-addressed Provenance Spine. PAPER separates administrative authority from horizontally scalable enforcement Relays and places a registered inference agent in front of model-serving engines. It reuses TLS 1.3, QUIC, deterministic CBOR, COSE, and standard signatures rather than proposing new cryptography.

We describe a Go prototype and report preliminary, single-machine measurements of implemented protocol primitives. Median encode/decode time is 290.2 ns for a 1 KiB record and 97.0 μ s for a 1 MiB record; an evidence-chain update takes 73.05 ns, and Ed25519 sign-and-verify takes 42.7 μ s. These results do not yet establish network, policy-pipeline, time-to-first-token, or production-scale overhead. We therefore distinguish measured prototype results from partially implemented and design-only claims, and specify the experiments required for a complete evaluation.

1 Introduction

Modern coding agents operate across boundaries that conventional model protocols do not model directly. A single task can disclose source files, use an organization instruction, invoke a model, propose a shell command, execute tests in a runtime, apply a patch, and create a commit. Each transition has a different authority source and may require a different enforcement decision. The security question is therefore no longer only whether a request was encrypted and authenticated. It is also whether the entire causal path from intent to artifact was authorized and can be verified later.

The common architecture combines an HTTPS model API, an AI gateway, policy middleware, runtime controls, observability, and source-control metadata. This decomposition is operationally useful, but identifiers and evidence are often joined after execution. Logs may have different retention, trust boundaries, clocks, and failure modes. A model-emitted tool proposal may be confused with actual execution, and a human-readable model name may obscure the package and endpoint that served the request.

PAPER explores a different boundary: governance state is carried as part of the live exchange. Figure 1 contrasts post-hoc reconstruction with a governed path in which authorization, enforcement, and evidence are linked before and during execution.

1.1 Contributions

This paper makes five design contributions and one preliminary empirical contribution:

1. **Governed Exchange.** A protected exchange is not executable until required identity, lease, policy, and Relay-decision state is present.
2. **Control/data-plane separation.** Policy authority remains in a control plane, while cacheable signed state enables Relays to enforce high-volume traffic without a database lookup per token.
3. **Causal evidence integration.** A content-addressed Provenance Spine links intent, context disclosure, infer-

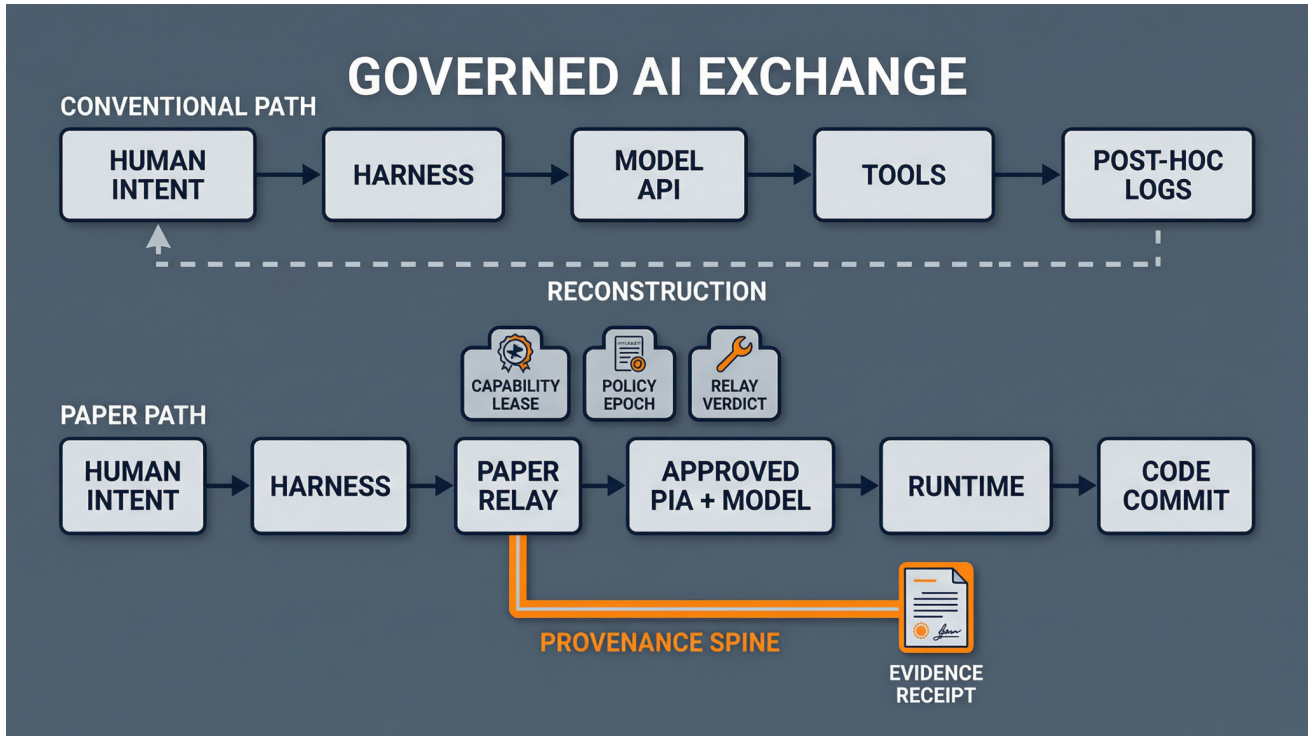


Figure 1: Conceptual overview of the design boundary. The upper path reconstructs governance from model/tool logs after execution. The lower path binds a Relay-mediated exchange to a Capability Lease, Policy Epoch, Relay Verdicts, approved inference infrastructure, and a continuous evidence chain. This illustration contains no empirical data.

ence, tool activity, edits, and artifacts; a per-exchange hash chain supports compact tamper evidence.

4. **Server-authoritative model identity.** A Catalog Model and capability descriptor are distinct from a signed model package and a leased serving endpoint.
5. **Capability-separated substrate.** Inference, tools, context, and collaboration lanes share authenticated session infrastructure without implicitly sharing authority or becoming model context.
6. **Prototype measurements.** We report reproducible microbenchmarks of record framing, canonical serialization, hashing, evidence-chain updates, and signatures, while explicitly withholding unmeasured end-to-end claims.

We do not claim to invent secure transport, capabilities, provenance DAGs, signed receipts, tool protocols, or prompt-injection defenses. The contribution is their lifecycle composition at the Harness-Relay-inference boundary.

2 Background and Adjacent Systems

Model APIs and gateways. HTTPS/JSON and streaming model APIs are effective request/response interfaces. Gateways can add authentication, quotas, policy, and logging. PAPER differs primarily in the unit of state: authorization and evidence are bound to a long-lived governed session and exchange rather than reconstructed

from independent middleware events.

MCP and A2A. The Model Context Protocol (MCP) standardizes interactions between AI applications and context/tool providers [8]. Agent2Agent (A2A) standardizes agent discovery, tasks, messages, and artifacts [1]. PAPER does not position either as an inferior transport. MCP can exist behind a governed tool broker, and A2A can operate at an agent-to-agent boundary. PAPER targets the narrower boundary between a human-facing engineering Harness, inline policy enforcement, controlled inference/runtime infrastructure, and software provenance.

Runtime governance and agent security. MI9 examines integrated runtime governance for agentic systems [15]; AgentDojo provides an environment for prompt-injection attacks and defenses [4]; and argument-level provenance work highlights the mismatch between coarse authorization and tool arguments [5]. PAPER is complementary: it defines protocol objects and state transitions through which identity, policy, tool authority, and evidence can be enforced and exported.

Supply-chain provenance. in-toto records signed metadata about supply-chain steps [6, 14], while SLSA defines provenance expectations for build and source tracks [11]. PAPER addresses an earlier interactive phase, before a build artifact necessarily exists. A PAPER receipt

may later feed an in-toto or SLSA-oriented attestation.

Identity and cryptographic building blocks. SPIFFE provides workload-identity conventions [12]. PAPER reuses TLS 1.3 [9], QUIC [7], deterministic CBOR [3], COSE [10], HPKE [2], and COSE receipts [13]. These standards provide transport and object-security primitives; they do not define the application-level authority model proposed here.

3 Requirements and Threat Model

3.1 Design requirements

The protocol is designed around six requirements: (R1) bind protected actions to an enrolled peer and user; (R2) constrain authority with short-lived, purpose-bound grants; (R3) bind enforcement to an immutable policy revision; (R4) identify approved model artifacts and endpoints more strongly than a caller-supplied name; (R5) distinguish a model’s proposed action from runtime authorization and execution; and (R6) emit causal evidence that can be verified independently of ordinary application logs.

The system must also operate with a temporarily unavailable control plane. Relays therefore consume signed or authenticated snapshots, revocation state, policy epochs, model catalogs, and leases. Availability under stale state is bounded by explicit expiration and deployment policy rather than implicit cache behavior.

3.2 Adversaries and non-goals

We consider network attackers, unregistered clients, stolen or replayed credentials, compromised Harnesses, prompt-injected content, malicious tool output, model-name spoofing, cross-tenant mistakes, and evidence tampering. A Relay or administrator may also be malicious or compromised. The protocol aims to make such authority and evidence boundaries explicit; it cannot make a trusted plaintext Relay unable to inspect content, prove that a model behaved correctly, or prevent a fully compromised endpoint from acting outside the protocol. Hardware attestation and formal verification are optional future profiles, not assumptions of the prototype.

4 Architecture

4.1 Peers and planes

The administrative Control Plane enrolls identities, issues policy and model state, manages revocation, and indexes evidence. A Relay terminates Harness connections, validates authority, performs inline policy decisions, routes

approved inference, and appends evidence. A Patty Inference Agent (PIA) is a registered peer placed in front of a serving engine. The PIA translates the protocol’s semantic request into a local engine interface; a raw engine endpoint is not a Harness trust boundary. A runtime executes tools only after independent authorization.

4.2 Transport and representation

QUIC is the preferred binding because independent streams reduce head-of-line coupling; TLS 1.3 over TCP is the fallback. Both use the same application semantics and ALPN identity. Records contain a fixed prelude, canonical header, payload, logical lane identifier, and lane sequence. Deterministic CBOR provides reproducible object encoding. COSE signatures protect credentials, leases, epochs, model manifests, and receipts where object-level verification is required.

Transport authentication alone is insufficient. An application proof must bind peer credential, nonces, negotiated profile, and channel context so that a credential proof captured on one connection cannot be replayed on another. The present prototype defines these messages but, as Section 7 explains, does not yet perform the complete production verification path.

5 Governance-Native Exchange Semantics

5.1 Identity, sessions, and Capability Leases

User identity, Harness identity, and workload/session identity are separate. Enrollment gives a Harness a peer credential; it does not grant unrestricted inference. A Working Session binds user, Harness, organization/project, purpose, repository, and effective policy. A Capability Lease then grants a subset of actions for a short interval: permitted models, context paths, tool classes, token budget, and approval requirements. Revocation or expiration prevents new protected actions even if the underlying transport remains connected.

5.2 Policy Epoch and Relay Verdict

A Policy Epoch is an immutable digest-addressed policy snapshot. Every protected exchange references an epoch. If policy changes mid-session, active work follows an explicit continue, rebind, pause, or terminate rule; it does not silently switch semantics. Before protected content reaches a PIA or runtime, the Relay emits a structured verdict such as allow, deny, transform, quarantine, or require approval. Verdict evidence identifies the policy epoch and rule set that produced it.

Table 1: Core authority and identity objects. Objects visible to the Harness are intentionally separated from deployment identities.

Object	Authority	Purpose	Important distinction
Peer credential	enrollment authority	Binds key, peer profile, tenant, and validity	Identifies software instance, not merely user
Capability Lease	policy authority	Grants bounded action/model/tool/context scope	Permission; not resource capacity
Policy Epoch	policy authority	Immutable effective policy revision	Exchange binds to a digest, not “latest”
Catalog Model	model catalog	Stable user-facing service identity	Contains no provider endpoint
Model Descriptor	model catalog	Declares semantic capabilities and client minimums	Negotiation, not authorization by itself
Model Package (PMP)	model authority	Signed artifact/template/quantization identity	Stronger than human-readable model name
Endpoint Lease	serving authority	Binds active PIA endpoint to approved package	Short-lived deployment state
Account Capacity Lease	capacity authority	Coordinates distributed workload slots	Capacity; distinct from action permission

5.3 Exchange lifecycle

A typical exchange progresses through OPEN, GOVERNANCE, ROUTE, STREAM, optional TOOL/APPROVAL, and CLOSE. The Relay validates the peer/session binding, Capability Lease, Policy Epoch, catalog model, model package, endpoint lease, and capacity state before dispatch. Token or data records are multiplexed over lanes with sequence numbers. Side-effecting actions carry an idempotency class so reconnect/resumption cannot silently duplicate a completed operation.

5.4 Server-authoritative model resolution

The v2 design adds an important identity separation:

Catalog Model $\rightarrow$ PMP $\rightarrow$ PIA Endpoint.

After authentication, the Harness receives an effective model catalog scoped by entitlement, organization policy, deployment profile, geography, and client capability. A Model Descriptor advertises supported semantic features—for example multimodal input, structured output, parallel tools, caching, reasoning controls, and resumability—without exposing an endpoint. An inference open message references the Catalog Model and Catalog Epoch. The Relay rejects stale or unauthorized identities, resolves a signed PMP, and selects an endpoint with a valid lease. This prevents a caller-supplied base URL or model alias from becoming routing authority.

5.5 Tool authority and prompt injection

A model output is a proposal, not authority. Tool descriptors specify execution placement, risk class, argument schema, approval policy, idempotency, and provenance requirements. Incrementally streamed arguments are not

executable until complete and authorized. Repository text, chat, files, and tool output retain trust labels but cannot enlarge lease scope. Prompt injection remains possible; the protocol contribution is to make authority external to model text and to record the inputs and decisions surrounding execution.

6 Causal Provenance and Receipts

Ordinary logs answer that events occurred. The Provenance Spine represents causal edges among human intent, selected context, policy decisions, model invocation, output, tool proposal, approval, execution result, edits, tests, review, and source-control artifacts. Nodes are content-addressed and typed; edges describe causation, derivation, disclosure, transformation, or binding.

For compact exchange integrity, let $r_0 = H(\text{domain} \parallel \text{exchange-open})$ and

$$r_i = H(\text{domain} \parallel r_{i-1} \parallel H(e_i)), \quad (1)$$

where e_i is the canonical representation of evidence event i . A signed Evidence Receipt binds the final root to the exchange, identities, policy epoch, model/package resolution, outcome, and retention/export profile. This construction provides tamper evidence, not truth by magic: a compromised authorized component can still emit false source data. Cross-component receipts and external transparency can reduce unilateral trust but are not complete in the prototype.

Selective export may replace sensitive nodes with commitments or redacted summaries while retaining verifiable linkage. Source-code attribution after refactoring or merging is probabilistic and should carry confidence and transformation history rather than a binary “AI-generated” label.

7 Prototype Implementation

The prototype is implemented in Go and evaluated at repository commit 0234034b51fb6f1a5127280ce1e9c209b8198004. It includes a 32-byte record prelude, bounded headers and payloads, canonical CBOR helpers, COSE Sign1 support, Ed25519 object signatures, content-addressed digests, evidence-chain primitives, peer/session state machines, TLS/TCP transport, a QUIC transport foundation, model/catalog schemas, policy and lease services, Relay/PIA components, vLLM/SGLang adapters, and conformance tests.

The current Relay can route an inference request to a PIA using a PAPER TLS/TCP connection and AI_OPEN/AI_COMPLETE records. The embedded semantic payload is currently JSON, and a legacy HTTP development fallback remains when the PAPER PIA address is not configured. This is a migration-stage implementation rather than the final canonical AI semantic encoding.

Several security-sensitive paths remain incomplete. The Relay listener receives an authentication proof but accepts a structurally valid development credential without verifying its production COSE signature, revocation, and handshake transcript. Development TLS configurations use self-signed certificates and disabled verification. Catalog validation in one pipeline path rejects an empty identifier but does not query the effective catalog cache; capacity validation and scheduler admission include permissive stubs. Some application-message handlers log rather than execute the full governance route. These limitations constrain all empirical claims in this paper.

8 Evaluation Methodology

The complete evaluation asks: (Q1) what connection and pre-inference latency does PAPER add; (Q2) how does Relay CPU/memory scale with streams; (Q3) what evidence/storage cost is incurred; (Q4) which adversarial cases are rejected; and (Q5) how accurately provenance survives software evolution?

8.1 Baselines

We define five goal-aware baselines: B0, a minimal secure binary stream; B1, bearer-authenticated HTTPS/JSON streaming; B2, HTTPS/JSON plus comparable gateway policy and logging; B3, PAPER with identity/session and minimal governance; and B4, PAPER with lease, policy, content checks, verdicts, and provenance. MCP and A2A should be compared semantically, not presented as performance competitors for goals they do not attempt.

End-to-end experiments must report connection p50/p95/p99, time to first Relay verdict, TTFT, inter-token latency, sustained throughput, CPU time, allocation, memory per stream, and evidence bytes. The environment disclosure must include CPU, memory,

NIC, RTT, topology, OS, Go and QUIC versions, model/quantization, GPU, policy modules, and storage backend.

8.2 Security and provenance experiments

Negative tests include an unknown peer, expired/replayed lease, unknown Policy Epoch, stale catalog, unapproved model package, invalid endpoint lease, profile-confused message, malformed state sequence, duplicate side effect after resume, prompt-injected capability escalation, and modified receipt. Provenance fidelity should be measured on generated functions followed by human edits, file re-names, function moves, rebases, merges, and multi-agent changes. Precision/recall and confidence calibration are more appropriate than anecdotal examples.

9 Preliminary Results

9.1 Experimental setup

Measurements ran locally on an Apple M4 Pro with 14 logical CPUs and 48 GiB RAM, macOS 27.0, arm64, and Go 1.26.5. Each Go benchmark was repeated five times; Table 3 reports the median. The command disabled ordinary tests for the benchmark package and enabled allocation reporting. The full repository test command subsequently passed. No network, database, model, GPU, or token generation was involved.

The record result scales approximately linearly across the measured sizes. The benchmark allocates an encoded buffer and decoded record on every iteration; consequently, bytes allocated are roughly twice the large payload size. The evidence-chain operation is small relative to a network or model call, but this does not imply that complete provenance is inexpensive: serialization, signatures, persistence, indexing, and retention are excluded.

The full repository suite passed at the evaluated commit. The conformance package exposes tests named for research invariants 1–5 and 7–12; invariant 6 has no named test. Moreover, several passing tests do not exercise their full invariant. The Policy Epoch test checks connection readiness rather than unknown-epoch rejection; the tool-authority test checks only credential validity; the reconnect test contains no assertion and refers to another package; and the profile-isolation test constructs a list without sending messages through an enforcing registry. We therefore report passing code tests, not “twelve invariants proven.”

9.2 Interpretation

These measurements establish that the implemented framing and cryptographic helper operations are benchmarkable and inexpensive on one modern CPU. They do not answer the central performance research question because the dominant overhead may reside in TLS/QUIC estab-

Table 2: Claim-to-evidence matrix for the evaluated snapshot. “Partial” means relevant code exists but the complete stated property is not exercised end to end.

Claim	Status	Available evidence	Permitted wording
Record framing and bounded parsing	Implemented	round-trip tests and microbenchmarks	Measured prototype primitive
Canonical CBOR and signature primitives	Implemented	unit tests and microbenchmarks	Measured prototype primitive
Tamper-evident evidence-chain update	Implemented primitive	deterministic hash tests and microbenchmark	Detects mutation under stated hash assumptions
TLS/TCP Relay-to-PIA PAPER exchange	Partial	implementation and package tests	Development vertical slice
Authenticated Harness-to-Relay exchange	Partial	message/state tests; proof verification incomplete	Protocol design with partial prototype
Catalog Model authorization	Partial	schemas/service tests; permissive pipeline path	Server-authoritative design under implementation
Account-wide distributed capacity enforcement	Design/scaffold	schema and service scaffolding	Not empirically established
Twelve research invariants enforced	Not established	eleven named tests; several placeholders	Candidate invariant suite only
Production latency, TTFT, scale, provenance fidelity	Unmeasured	methodology only	No result claim

Table 3: Preliminary in-memory primitive medians over five runs. Record tests include encode and decode.

Operation	Time/op	B/op	allocs
Record, 1 KiB	290.2 ns	2,384	7
Record, 64 KiB	8.46 μ s	139,472	7
Record, 1 MiB	97.0 μ s	2,105,556	7
CBOR Hello round trip	599.4 ns	592	9
Evidence-chain update	73.05 ns	32	1
1 KiB object digest	403.1 ns	32	1
Ed25519 sign+verify	42.7 μ s	64	1

lishment, policy modules, database/cache access, scanning/classifiers, network placement, model scheduling, or storage. The B0–B4 experiments remain required before making a system-overhead claim.

10 Comparative Analysis

Table 4 locates novelty in composition and lifecycle semantics rather than lower-layer mechanisms. A conventional gateway could implement many PAPER concepts. The research question is whether defining common state transitions, identities, evidence objects, and transport semantics improves enforceability and interoperability enough to justify a stateful protocol.

11 Security Analysis

An unregistered generic client lacks a valid peer credential and session grant; a stolen Harness key remains bounded

by lease lifetime, repository/purpose scope, revocation, and optional device evidence. A fake model name cannot select an endpoint when the Relay resolves only an authorized Catalog Model through a signed PMP and active Endpoint Lease. A prompt-injected tool call cannot grant itself authority because runtime execution performs an independent lease/policy check.

Replay protection requires transcript-bound authentication and idempotency evidence. Transport fallback must preserve the same authorization objects and state machine. Evidence tampering changes the chain root, while an attacker able to compromise all receipt signers can still forge a consistent account. A malicious inspectable Relay can read plaintext and may omit or distort events; cross-component receipts, limited retention, independent export, and optional payload protection reduce but do not eliminate this trust.

The prototype does not yet establish these end-to-end properties. In particular, placeholder proof material and permissive certificate verification mean that the development transport must not be described as production peer authentication.

12 Deployment and Migration

One protocol kernel can support public cloud, enterprise, and sovereign profiles by varying enabled modules, policy defaults, retention, mobility, and infrastructure placement rather than forking wire semantics. Sovereign deployment may use local PKI, catalogs, PIA endpoints, and offline-signed update bundles. This is a design target, not an interoperability result.

Because PCCP already has administrative and legacy

Table 4: Goal-aware qualitative comparison. A blank objective is not a deficiency when a system intentionally addresses another boundary.

System family	Primary boundary	Live purpose-bound authority	Inline model/package identity	Interactive causal code provenance
Model API	application-model service	typically application-defined	usually caller-visible model identifier	external
AI gateway	application-provider mediation	gateway/policy dependent	provider-route dependent	logs/plugin-ins
MCP	AI application-tool/context provider	authorization is deployment-specific	not its objective	not its objective
A2A	agent-agent task/artifact exchange	protocol/task dependent	not its objective	not its objective
in-toto/SLSA	software supply-chain steps/artifacts	step/build policy	artifact identity	post-step/build provenance
PAPER	Harness-Relay-PIA/runtime	Capability Lease + Policy Epoch	Catalog Model + PMP + Endpoint Lease	native exchange graph/receipt

request paths, adoption is brownfield. A safe sequence inventories callers, introduces catalog/control schemas additively, runs the PAPER Relay beside the legacy gateway, dual-records comparable requests, canaries Harness cohorts, blocks generic routing for migrated clients, and removes the old path only after telemetry and rollback gates are satisfied. A migration evaluation should compare normalized usage, chosen model package, tool outcome, and evidence between old and new paths.

13 Discussion and Limitations

Scope pressure. Inference, tools, context, files, chat, voice, and directives can share identity and session infrastructure, but a broad substrate increases implementation and review cost. The core paper is strongest when these are capability-separated extensions rather than equally mature contributions.

State and operations. Leases, epochs, resumption, revocation, catalogs, and evidence add operational burden. Cache staleness and control-plane partitions require explicit fail-closed, bounded-stale, or degrade behavior. Binary framing also requires first-class diagnostics and capture tooling.

Privacy. Fine-grained provenance can become employee surveillance. Deployments need purpose limitation, minimization, role-separated access, retention bounds, selective export, and notice. Content-addressing does not anonymize sensitive content; unsalted hashes can enable guessing attacks.

Implementation maturity. Only primitive overhead is measured. Production authentication, complete catalog/capacity enforcement, QUIC/TCP equivalence, independent interoperability, fuzzing, security review, scale,

TTFT, and provenance-fidelity datasets remain open. The implementation contains a legacy development fallback and JSON semantic payload that must be removed or formally profiled before claiming a PAPER-only canonical path.

No formal proof. The state machine and invariants are candidates for formal modeling, but no formal security proof is claimed. Provenance establishes recorded causality under component assumptions, not semantic correctness or authorship truth.

14 Ethics and Governance

Evidence about prompts, files, tool use, edits, and human decisions can improve incident response and accountability while also enabling disproportionate monitoring. The protocol therefore supports retention and export profiles, but technical configurability is insufficient. Deployments should establish lawful purpose, employee notice, access review, appeal, data-subject handling, and a separation between security investigations and performance management. Public deployments should default to operationally minimal traces; regulated deployments should justify deeper retention per policy domain.

Generated conceptual artwork is used only for Figure 1; it communicates architecture and contains no measurement or factual comparison. Empirical tables are derived directly from checked-in benchmark output.

15 Reproducibility

The accompanying artifact contains the exact LaTeX source, bibliography, conceptual figure, benchmark data, Go benchmark harness, and build instructions. The preliminary measurements can be reproduced with:

```
go test ./internal/paper -run '$' -bench
'Benchmark(...)' -benchmem -count=5
```

where the artifact README provides the complete regular expression. The PDF builds offline with `latexmk` and BibTeX. A complete empirical release should additionally publish raw per-run output, network/load generators, topology automation, negative-security fixtures, provenance datasets, and independent implementation results.

16 Conclusion

PAPER proposes governance-native communication for human-AI software engineering: authority, immutable policy, inline enforcement, model/package resolution, and causal evidence become properties of the live exchange. The Go prototype implements framing, serialization, cryptographic and evidence primitives, transport foundations, governance schemas, and a development Relay-to-PIA vertical slice. Preliminary microbenchmarks show these primitives are measurable and small on one modern CPU, but do not establish end-to-end system overhead or production security.

The next evidentiary threshold is clear: complete authentication and enforcement paths, B0-B4 network and inference comparisons, executable invariant coverage, independent interoperability, adversarial testing, and a provenance-fidelity dataset. Until then, PAPER should be evaluated as a protocol design with a partial, measured prototype—not as a production-complete or formally verified security system.

References

- [1] A2A Project. Agent2agent protocol specification, 2026. <https://a2a-protocol.org/latest/specification/>.
- [2] R. Barnes, K. Bhargavan, and C. A. Wood. Hybrid public key encryption. Technical Report RFC 9180, IETF, Feb. 2022. <https://www.rfc-editor.org/info/rfc9180>.
- [3] C. Bormann and P. Hoffman. Concise binary object representation (CBOR). Technical Report RFC 8949, IETF, Dec. 2020. <https://www.rfc-editor.org/info/rfc8949>.
- [4] E. Debenedetti, J. Zhang, M. Balunović, L. Beurer-Kellner, M. Fischer, and F. Tramèr. AgentDojo: A dynamic environment to evaluate prompt injection attacks and defenses for llm agents. *arXiv preprint arXiv:2406.13352*, 2024. <https://arxiv.org/abs/2406.13352>.
- [5] L. Fan, Z. Li, Y. Tian, Y. Wang, R. Li, and X. Wang. The granularity mismatch in agent security: Argument-level provenance solves enforcement and isolates the llm reasoning bottleneck. *arXiv preprint arXiv:2605.11039*, 2026. <https://arxiv.org/abs/2605.11039>.
- [6] in-toto Project. in-toto specification v1.0, 2023. <https://in-toto.io/docs/specs/>.
- [7] J. Iyengar and M. Thomson. QUIC: A UDP-based multiplexed and secure transport. Technical Report RFC 9000, IETF, May 2021. <https://www.rfc-editor.org/info/rfc9000>.
- [8] Model Context Protocol Project. Model context protocol specification, 2025-06-18 revision, 2025. <https://modelcontextprotocol.io/specification/2025-06-18>.
- [9] E. Rescorla. The transport layer security (tls) protocol version 1.3. Technical Report RFC 9846, IETF, July 2026. <https://www.rfc-editor.org/info/rfc9846>.
- [10] J. Schaad. CBOR object signing and encryption (COSE): Structures and process. Technical Report RFC 9052, IETF, Aug. 2022. <https://www.rfc-editor.org/info/rfc9052>.
- [11] SLSA Project. SLSA specification v1.2, 2026. <https://slsa.dev/spec/v1.2/>.
- [12] SPIFFE Project. Secure production identity framework for everyone standard, 2026. <https://spiffe.io/docs/latest/spiffe-specs/spiffe/>.
- [13] O. Steele, H. Birkholz, A. Delignat-Lavaud, and C. Fournet. CBOR object signing and encryption (COSE) receipts. Technical Report RFC 9942, IETF, June 2026. <https://www.rfc-editor.org/info/rfc9942>.
- [14] S. Torres-Arias, H. Afzali, T. K. Kuppusamy, R. Curtmola, and J. Cappos. in-toto: Providing farm-to-table guarantees for bits and bytes. In *28th USENIX Security Symposium*, pages 1393–1410, 2019.
- [15] C. L. Wang, T. Singhal, A. Kelkar, and J. Tuo. MI9: An integrated runtime governance framework for agentic ai. *arXiv preprint arXiv:2508.03858*, 2025. <https://arxiv.org/abs/2508.03858>.

A Research Invariant Coverage

Table 5 audits the conformance-test coverage at the evaluated commit. “Weak” denotes an assertion that does not exercise the full invariant stated by its test name; “partial” denotes a meaningful primitive or state check without a complete end-to-end path.

Table 5: Coverage audit of the candidate research invariants.

ID	Candidate invariant	Coverage	Audit note
I1	No protected action before peer authentication	Partial	connection-state gating asserted; listener proof verification incomplete
I2	No protected action outside a valid Capability Lease	Weak	test checks credential time validity, not action authorization
I3	No action under an unknown Policy Epoch	Weak	test checks connection readiness, not epoch lookup/rejection
I4	No invocation against an unapproved package/endpoint lease	Partial	signature mutation tested; full route binding not exercised
I5	Tool proposal grants no authority by itself	Weak	test checks only a valid peer credential
I6	Context disclosure requires explicit authority	Missing	no named conformance test
I7	Transport fallback preserves authorization semantics	Weak	ALPN constant checked; fallback exchange not exercised
I8	Reconnect does not duplicate completed side effects	Placeholder	named test has no assertion
I9	Protected exchange terminates with verifiable evidence	Partial	deterministic chain checked; termination/receipt path not exercised
I10	Provenance mutation changes digest	Implemented primitive	distinct content produces distinct domain-separated digest
I11	Peer profiles cannot emit privileged messages	Placeholder	message list is constructed but not passed through enforcement
I12	Administrative communication and enforcement are distinct	Structural	distinct message type codes asserted

A.1 Required Completion Experiments

The following gates separate the preliminary artifact from a complete empirical revision:

1. **Transport and authentication:** exercise full certificate and COSE proof verification, revocation, transcript binding, resumption, and QUIC-to-TCP fallback with p50/p95/p99 connection measurements.
2. **End-to-end inference:** compare B0–B4 on identical payloads and model output, reporting Relay verdict latency, TTFT, streaming throughput, CPU, allocation, and memory.
3. **Governance negatives:** reject expired/replayed leases, unknown epochs, stale catalogs, unapproved packages, invalid endpoints, profile-confused messages, and duplicate side effects through the actual Relay path.
4. **Scale and failure:** measure concurrent sessions/streams, Relay restart, control-plane loss, bounded-stale caches, capacity-authority loss, and evidence-backend degradation.
5. **Provenance fidelity:** publish a labeled dataset covering human edits, file/function moves, rebases, merges, and multi-agent changes with precision, recall, and confidence calibration.
6. **Independent evidence:** demonstrate an implementation not sharing the complete Go stack, publish golden vectors/fuzz results, and obtain an external security review before a production-security claim.